



Guía de implementación del Marco de ciberseguridad 5.0

GR.2 Realizar de manera sistemática el proceso de evaluación de riesgos

Requisito GR.2	Realizar de manera sistemática el proceso de evaluación de riesgos
Objetivo	Contribuir al cumplimiento de los objetivos de seguridad de la información, prevenir o reducir los efectos no deseados y lograr la mejora continua.
Controles	Nivel 1 - GR.2-1: Se identifican los principales riesgos de seguridad de la información, valorando su potencial impacto y su probabilidad de ocurrencia. Nivel 2 - GR.2-2: Las amenazas, vulnerabilidades y controles existentes en la organización están documentados. - GR.2-3: Se cuenta con un inventario de riesgos de seguridad de la información que incluye riesgos asociados a todos los activos de información (se incluyen riesgos positivos). Nivel 3 - GR.2-4: El apetito de riesgo y la tolerancia al riesgo se ha definido formalmente por el negocio. - GR.2-5: Se incorporan riesgos vinculados a la cadena de suministro. - GR.2-6: Los incidentes de seguridad de la información y ciberseguridad son tenidos en cuenta para la evaluación de riesgos. Nivel 4 - GR.2-7: Debe revisarse periódicamente la tolerancia al riesgo establecida, y modificarse ante cambios normativos, tecnológicos o necesidades del negocio. - GR.2-8: Los riesgos se revisan periódicamente, la revisión se documenta formalmente.

Requisito GR.2	Realizar de manera sistemática el proceso de evaluación de riesgos
Guía de implementación	Evaluación de riesgos De acuerdo a lo definido en el proceso de evaluación de riesgos de seguridad, se debe: • Establecer el alcance. • Identificar y documentar las amenazas y vulnerabilidades. • Identificar el impacto en el negocio en caso de materializarse los riesgos. • Clasificar y monitorear los riesgos. • Establecer la periodicidad de las evaluaciones. Los riesgos deben ser evaluados en toda la cadena de suministro y delegar obligaciones en los casos que corresponda.
Instituciones de salud	Se debe realizar una evaluación de los posibles riesgos y vulnerabilidades a la confidencialidad, integridad y disponibilidad de la Historia Clínica Electrónica (HCE). Además, se debe realizar una evaluación de riesgos con relación a la conectividad de dispositivos médicos, contemplando: identificación de activos, identificación de tipo de conectividad, casos de uso, flujos de comunicación, exposición de servicios a Internet, segregación/segmentación para ubicar estos activos, control de acceso a los dispositivos y a la red, acceso remoto, cifrado de comunicación en tránsito, uso de certificados, gestión, operación y monitoreo de los dispositivos, hardening, etc.
Instituciones Emisoras de Dinero Electrónico (IEDE)	Se gestionan los riesgos de las API o Servicios Web suministrados por los proveedores de servicios de computación en la nube.
Guía de evidencia para auditoría	• Inventario de riesgos identificados y seguimiento para el período auditado. • Evaluación y/o análisis de riesgos. • Evaluaciones de riesgos de proveedores críticos.
Normativa asociada	No aplica

← [GR.1 Adoptar una metodología de Evaluación de Riesgo](#)

[GR.3 Plan de acción para riesgos detectados e implementación de medidas correctivas y preventivas](#) →

[Ir al Índice](#)

Etiquetas

[Gestión y auditoría de Seguridad de la Información](#)

[Marco de Referencia](#)

[Política Digital del Uruguay](#)

[Políticas de Ciberseguridad](#)

[Ciberseguridad](#)

[Herramientas para la ciudadanía](#)

[Herramientas para organismos](#)

[Política Digital del Uruguay](#)

Índice

Introducción

Objetivo y Alcance

Requisitos

Organización y Gobernanza

Gestión de Riesgos

Gestión humana

Gestión de activos

Control de acceso

Seguridad física y del ambiente

Seguridad de las operaciones

Seguridad de las comunicaciones

Adquisición, desarrollo y mantenimiento de los sistemas

Relación con proveedores

Gestión de incidentes

Continuidad de las operaciones

Cumplimiento normativo y revisión

Protección de datos personales

Agencia de Gobierno Electrónico y Sociedad de la Información y del Conocimiento

Dirección: Liniers 1324 piso 4 (Montevideo, Uruguay)

Teléfono: (+598) 2901 2929

Contacto

Horario de atención: lunes a viernes de 9:00 a 17:00 h.

gub.uy